

Aula 4 (Módulo 03) — DNS

1. O problema que DNS resolve

Computadores se comunicam por **IP** (Aula 1), mas seres humanos lembram melhor de **nomes** (`google.com` , `github.com`). **DNS** (*Domain Name System*) é o sistema que traduz nomes de domínio em endereços IP — é literalmente a "lista telefônica" da internet.

```
Você digita:  github.com
DNS resolve:  github.com → 140.82.112.3 (exemplo)
Seu navegador conecta: 140.82.112.3:443
```

2. Como a resolução funciona (visão simplificada)

```
Seu computador
→ pergunta ao servidor DNS configurado (ex.: o do seu provedor,
    ou 8.8.8.8 do Google, 1.1.1.1 da Cloudflare)
    → se esse servidor não sabe, ele pergunta a servidores "acima"
        na hierarquia (servidores raiz → servidores do domínio de
            topo ".com" → servidor autoritativo de "github.com")
← recebe a resposta: o IP correspondente
```

Normalmente isso usa **UDP na porta 53** (lembra da Aula 3? DNS é o exemplo clássico de uso de UDP, por precisar ser rápido) — embora existam variantes modernas sobre TCP também, especialmente para respostas grandes ou para versões criptografadas do protocolo (**DoH** — DNS over HTTPS, **DoT** — DNS over TLS), que existem justamente para impedir que alguém no meio do caminho veja ou altere suas consultas DNS.

3. Tipos de registro DNS mais comuns

Tipo	O que faz
A	Nome de domínio → endereço IPv4
AAAA	Nome de domínio → endereço IPv6
CNAME	Um nome é "apelido" de outro nome (redireciona a resolução)
MX	Define qual servidor recebe e-mails daquele domínio
TXT	Texto livre — usado para verificação de domínio e, importante, SPF/DKIM/DMARC (mecanismos que ajudam a combater falsificação de e-mail — veremos com mais detalhe quando chegarmos a phishing)
NS	Define quais servidores são autoritativos para aquele domínio

```
nslookup github.com      # consulta simples (Linux/Windows)
dig github.com            # consulta mais detalhada (Linux/macOS)
dig github.com MX        # consulta um tipo específico de registro
```

4. Por que DNS é tão relevante para segurança

DNS como primeira pista de comprometimento

Antes mesmo de um processo malicioso abrir uma conexão de rede completa, ele frequentemente faz uma **consulta DNS** primeiro (para descobrir o IP do servidor de C2, por exemplo). Lembra do Sysmon Event ID 22 (Módulo 02, Aula 5)? Ele existe exatamente para capturar isso — consultas DNS são, muitas vezes, o **primeiro sinal** de comunicação maliciosa, antes mesmo da conexão de rede em si.

DNS Tunneling

Como muitos firewalls permitem DNS livremente (é considerado tráfego "inofensivo" de infraestrutura), atacantes às vezes escondem **dados** dentro de consultas DNS (nomes de domínio muito longos e estranhos, codificando informação) para contornar controles de segurança — tanto para receber comandos quanto para **exfiltrar dados** aos poucos. Isso é chamado de **DNS Tunneling**, catalogado como **T1071.004 – Application Layer Protocol: DNS**.

Domain Generation Algorithm (DGA)

Alguns malwares, em vez de terem um domínio de C2 fixo (fácil de bloquear), geram **centenas de nomes de domínio aleatórios por dia** matematicamente, e tentam se conectar a cada um até achar o que o atacante realmente registrou naquele dia — dificultando o bloqueio por lista fixa. Um sinal de detecção: muitas consultas DNS seguidas, para domínios com nomes estranhos/aleatórios, que **falham** (NXDOMAIN — domínio não existe) é um padrão suspeito de DGA.

Typosquatting

Registrar domínios parecidos com marcas conhecidas, com erros de digitação sutis (`google.com`, `github-login.com`, `paypa1.com`), usados em campanhas de phishing. Reconhecer isso é uma habilidade central tanto para Threat Intelligence (Módulo 12) quanto para qualquer usuário comum se proteger.

5. Conectando tudo

```
DNS traduz nome → IP
├ é frequentemente o PRIMEIRO indício de atividade maliciosa
│ (antes mesmo da conexão de rede acontecer)
├ pode ser abusado para exfiltração/C2 disfarçado (DNS tunneling)
├ pode indicar malware com DGA (muitos NXDOMAIN seguidos)
└ domínios parecidos com marcas legítimas = typosquatting/phishing
```

6. Exercício prático

```
dig github.com
dig github.com MX
nslookup dominio-que-nao-existe-teste-123456.com
```

No último comando, observe a resposta `NXDOMAIN` — é exatamente esse tipo de resposta que, em grande volume e repetição, levanta suspeita de DGA em um ambiente monitorado.

7. Recapitulando

- DNS traduz nomes de domínio em IP, geralmente via UDP/53 (com variantes criptografadas modernas: DoH, DoT).
- Registros A/AAAA (IP), CNAME (apelido), MX (e-mail), TXT (verificação/SPF-DKIM-DMARC), NS (autoridade).
- Consulta DNS é frequentemente o **primeiro sinal** de atividade maliciosa (Sysmon Event ID 22).
- DNS Tunneling (T1071.004), DGA (muitos NXDOMAIN de nomes aleatórios) e typosquatting são os três padrões de abuso de DNS mais importantes de reconhecer.

Próxima aula

DHCP, NAT, roteamento, switching e VLAN — como dispositivos recebem IP automaticamente, como redes privadas "saem" para a internet compartilhando um único IP público, e como tráfego é encaminhado entre redes.

Fontes recomendadas

- **RFC 1035 — "Domain Names - Implementation and Specification"**: especificação técnica oficial (IETF) do DNS.
<https://www.rfc-editor.org/rfc/rfc1035>
- **MITRE ATT&CK — T1071.004 (Application Layer Protocol: DNS)**: técnica oficial de C2/exfiltração via DNS.
<https://attack.mitre.org/techniques/T1071/004/>
- **CISA — orientações sobre DNS Tunneling e proteção de infraestrutura DNS**: consulte cisa.gov para recomendações atualizadas.